

ROTEIRO TÉCNICO

E SITUAÇÃO DE APRENDIZAGEM

PARA O

TÉCNICO EM

DESENVOLVIMENTO

DE SISTEMAS



A formação profissional no âmbito do Serviço Nacional de Aprendizagem Industrial de Minas Gerais (SENAI MG) é pautada pela Metodologia SENAI de Educação Profissional, que prioriza o desenvolvimento de competências por meio de estratégias desafiadoras como a situação-problema e o estudo de caso.

No curso Técnico em Desenvolvimento de Sistemas, a unidade curricular de Banco de Dados assume um papel central, visto que o técnico é o profissional responsável por promover a interação entre as necessidades humanas e a programação de dispositivos, sempre zelando pela integridade e segurança da informação.

O domínio da administração de dados transcende a simples escrita de consultas SQL; ele exige uma compreensão holística de como os dados são armazenados, protegidos e rastreados em ecossistemas complexos, especialmente em um mercado cada vez mais pautado pela Indústria 4.0 e pelas diretrizes da Lei Geral de Proteção de Dados (LGPD).

O Contexto da Formação Profissional e a Administração de Dados

A unidade curricular de Banco de Dados, com carga horária de 120 horas no itinerário nacional, visa capacitar o aluno a instalar, configurar e manter sistemas de gerenciamento de banco de dados (SGBD) seguindo normas técnicas de qualidade e segurança.

A prática profissional demanda que o estudante não apenas identifique a arquitetura do banco de dados, mas saiba aplicar linguagens de manipulação (DML) e definição (DDL) de forma a garantir que a informação permaneça robusta e protegida contra ameaças internas e externas.

A segurança da informação é um componente transversal: ela deve estar presente desde a modelagem conceitual até a implementação de rotinas de backup e restore.

A relevância deste conhecimento é acentuada pela atuação do técnico em empresas de TI, consultorias e indústrias que demandam sistemas de alta disponibilidade.

Em Minas Gerais, o setor industrial exige que o técnico saiba lidar com grandes volumes de dados (Big Data) e integre sistemas de automação com camadas de software corporativo, onde a falha na segurança de um banco de dados pode paralisar uma linha de produção ou comprometer a propriedade intelectual de uma organização.

Métodos de Segurança de Dados: Uma Abordagem Técnica

A segurança de dados é um processo contínuo que protege as informações digitais contra corrupção e acesso não autorizado durante todo o seu ciclo de vida. Para o administrador de dados, essa proteção é implementada por meio de quatro pilares fundamentais: criptografia, mascaramento, controle de acesso e políticas de backup.

Criptografia e Proteção da Confidencialidade

A criptografia é o processo de utilizar algoritmos para tornar os dados ilegíveis para qualquer pessoa que não possua a chave de descriptografia correspondente. Na administração de bancos de dados, a criptografia deve ser aplicada tanto aos dados em repouso (at rest), armazenados nos discos do servidor, quanto aos dados em trânsito (in transit), que trafegam pela rede entre a aplicação e o SGBD.

O uso do padrão AES-256 (Advanced Encryption Standard) é a recomendação técnica para dados em repouso, enquanto protocolos SSL/TLS são mandatórios para assegurar a comunicação.

Camada de Proteção	Método de Criptografia	Objetivo Técnico
Aplicação para Banco	SSL/TLS (Criptografia em trânsito)	Impedir a interceptação de dados por ataques de "Man-in-the-Middle".
Armazenamento (Disco)	AES-256 (TDE - Transparent Data Encryption)	Proteger os arquivos de dados (.mdf,.db) em caso de furto do hardware.
Colunas Sensíveis	Criptografia em nível de coluna	Garantir que nem mesmo o administrador (DBA) veja dados

		como senhas ou cartões.
Backups	Criptografia de arquivo de backup	Assegurar que as cópias de segurança não sejam restauradas por pessoas não autorizadas.

A gestão de chaves é um ponto crítico: o armazenamento de chaves em módulos de segurança de hardware (HSM) ou serviços de cofre digital (como o HashiCorp Vault ou Azure Key Vault) garante que as chaves de acesso não fiquem vulneráveis no mesmo ambiente que os dados.

Mascaramento de Dados e Anonimização

O mascaramento de dados (Data Masking) é uma técnica de ofuscamento que substitui dados reais por dados fictícios, mantendo a estrutura original para fins de teste ou desenvolvimento. Ao contrário da criptografia, o mascaramento é frequentemente irreversível e visa a proteção de informações pessoalmente identificáveis (PII) em ambientes não-produtivos.

Existem dois tipos principais de mascaramento:

1. **Mascaramento Estático (Static Data Masking):** Uma cópia da base de dados de produção é criada e os dados sensíveis são permanentemente alterados antes de serem enviados para os desenvolvedores. É a prática recomendada para conformidade com a LGPD em ciclos de teste.
2. **Mascaramento Dinâmico (Dynamic Data Masking):** O dado original permanece intacto no banco de dados, mas o SGBD aplica uma máscara em tempo real durante a consulta (SELECT), dependendo dos privilégios do usuário. Por exemplo, um atendente de suporte visualiza apenas os últimos quatro dígitos de um cartão de crédito.

Controle de Acesso e Princípio do Menor Privilégio

O controle de acesso em bancos de dados deve ser fundamentado na identidade e no Princípio do Menor Privilégio, onde cada usuário ou aplicação possui apenas o acesso estritamente necessário para realizar suas tarefas.

A implementação técnica envolve a criação de perfis (Roles) e a atribuição de permissões granulares, evitando-se o uso de contas genéricas ou administrativas para operações rotineiras.

A autenticação multifator (MFA) e o uso de firewalls de banco de dados, que filtram o tráfego por endereço IP e assinaturas de consultas SQL suspeitas, adicionam camadas extras de defesa. A administração deve revisar periodicamente as permissões concedidas, removendo acessos de usuários que mudaram de função ou saíram da organização.

Estratégias de Backup e Recuperação

O backup é a operação de manutenção que garante a restauração dos dados em caso de falha de hardware, corrupção ou ataque de ransomware. O técnico deve planejar rotinas que incluam backups completos, diferenciais e de logs de transação, permitindo a recuperação em um ponto específico do tempo (Point-in-Time Recovery).

Um plano de backup robusto deve considerar:

- **RPO (Recovery Point Objective):** Define a quantidade de dados que a empresa aceita perder (ex: backups de log a cada 15 minutos significam um RPO de 15 minutos).
- **RTO (Recovery Time Objective):** Define o tempo máximo necessário para restaurar o sistema após um desastre.
- **Regra 3-2-1:** Manter 3 cópias dos dados, em 2 mídias diferentes, com 1 cópia armazenada fora do site (off-site ou cloud).

Rastreabilidade: Logs de Auditoria e Monitoramento

A rastreabilidade é a capacidade de identificar quem acessou ou modificou determinado dado, quando a ação ocorreu e qual ferramenta foi utilizada. Essa funcionalidade é essencial para garantir o não-repúdio, impedindo que um usuário negue ter realizado uma transação ou alteração no sistema.

Implementação de Auditoria no SQL Server

Para garantir o não-repúdio no SQL Server, o administrador deve configurar dois componentes: o **Server Audit** e o **Database Audit Specification**. O primeiro define o destino dos logs (um arquivo binário protegido ou o log de eventos do Windows), enquanto o segundo define as ações a serem monitoradas em um banco específico.

Passo de Implementação	Ação Técnica	Finalidade
1. Criar Server Audit	CREATE SERVER AUDIT definindo o FILEPATH	Estabelecer o repositório seguro para os logs.
2. Definir Política de Falha	Configurar ON_FAILURE = FAIL_OPERATION	Impedir transações se a auditoria não puder ser gravada.
3. Criar Database Spec	CREATE DATABASE AUDIT SPECIFICATION	Selecionar tabelas e comandos (SELECT, UPDATE) a auditar.
4. Ativar Auditoria	ALTER SERVER AUDIT... WITH (STATE = ON)	Iniciar o monitoramento em tempo real.

Monitoramento de Transações com Change Data Capture (CDC)

O monitoramento de transações pode ser aprimorado com o uso do Change Data Capture (CDC), que captura inserções, atualizações e exclusões aplicadas às tabelas, armazenando o histórico em tabelas de alteração de fácil consulta.

Diferente dos gatilhos (triggers), o CDC tem baixo impacto de performance, pois lê as informações diretamente do log de transações do SGBD.

No MySQL, a implementação de logs de auditoria pode ser feita via plugins específicos ou através do recurso de Servidor Flexível em nuvem, permitindo rastrear eventos de conexão e comandos DDL/DML para conformidade com a LGPD.

A análise constante desses logs permite identificar atividades suspeitas, como acessos em horários não comerciais ou tentativas massivas de exportação de dados.

Ferramentas da Qualidade Aplicadas à Segurança de Dados

A melhoria contínua dos processos de segurança é facilitada pelo uso de ferramentas da qualidade. O ciclo PDCA e o diagrama de Ishikawa são fundamentais para diagnosticar vulnerabilidades e estruturar ações corretivas eficazes.

Aplicação do Ciclo PDCA na Segurança de Bancos de Dados

O ciclo PDCA (Plan-Do-Check-Act) é um método iterativo de gestão que visa o aprimoramento constante.

1. **Planejar (Plan):** Identificar os ativos críticos e as vulnerabilidades do banco de dados. Definir indicadores de segurança, como número de acessos falhos ou tempo de inatividade. Estabelecer metas para redução de riscos cibernéticos.
2. **Fazer (Do):** Implementar as medidas técnicas planejadas, como a ativação de criptografia, criação de novos perfis de acesso e configuração de rotinas de auditoria. É essencial treinar a equipe de desenvolvimento sobre as novas políticas de segurança.
3. **Verificar (Check):** Analisar os resultados das implementações. Realizar testes de restauração de backup e auditorias nos logs para verificar se as permissões estão sendo seguidas. Comparar os dados de incidentes antes e depois das ações.
4. **Agir (Act):** Se os objetivos foram alcançados, padronizar os processos (ex: criar um manual de configuração de novos bancos). Se houve falhas, investigar as causas e reiniciar o ciclo com novos planos de ação.

Diagrama de Ishikawa para Análise de Vulnerabilidades

O diagrama de Ishikawa (ou espinha de peixe) ajuda a identificar a causa raiz de um problema de segurança, dividindo-as em categorias conhecidas como os 6Ms.

- **Mão de Obra:** Desenvolvedores sem treinamento em segurança, usuários compartilhando senhas ou DBAs que utilizam contas administrativas para tarefas comuns.
- **Método:** Ausência de política de backup, procedimentos de atualização de patch mal definidos ou falta de um checklist para criação de novos usuários.
- **Máquina:** Servidores com hardware obsoleto, falta de redundância de discos (RAID) ou sistemas operacionais sem atualizações de segurança.
- **Material:** Versões de SGBD descontinuadas pelo fabricante ou uso de drivers de conexão com vulnerabilidades conhecidas.
- **Medição:** Logs de auditoria desativados, falta de monitoramento de performance ou ausência de alertas de espaço em disco.
- **Meio Ambiente:** Datacenter com controle de temperatura inadequado, exposição física do servidor a pessoas não autorizadas ou instabilidade na rede elétrica.

A Segurança na Indústria 4.0 e a Realidade do Mercado

A Indústria 4.0 integra tecnologias como IoT, IA e Big Data para tornar as fábricas mais inteligentes e eficientes. No entanto, essa conectividade massiva amplia a superfície de ataque, tornando a segurança de bancos de dados uma prioridade estratégica.

Sistemas ciberfísicos dependem da integridade dos dados para tomar decisões em tempo real; uma alteração maliciosa em um banco de dados de produção pode causar danos físicos a máquinas ou acidentes de trabalho.⁸

No mercado brasileiro, a conformidade com a LGPD (Lei 13.709/2018) é um requisito legal para qualquer empresa que trate dados pessoais com fins econômicos.

O técnico em desenvolvimento de sistemas deve projetar sistemas considerando a "Privacy by Design", onde a proteção de dados é integrada desde a fase de modelagem.

Falhas de segurança podem resultar em multas pesadas e danos irreparáveis à reputação das empresas.

Tecnologia 4.0	Impacto nos Dados	Risco de Segurança
IoT (Sensores)	Geração de dados contínua e massiva.	Injeção de dados falsos para sabotagem industrial.
Cloud Computing	Armazenamento de dados fora do perímetro físico.	Acesso não autorizado via credenciais de nuvem comprometidas.
Big Data	Processamento de volumes complexos de PII.	Dificuldade em rastrear e mascarar dados em tempo real.
Gêmeos Digitais	Replicação fiel de processos industriais em dados.	Roubo de segredos industriais e propriedade intelectual.

Situação de Aprendizagem: Estudo de Caso de Vazamento Industrial

Cenário Hipotético

A "Indústria Siderúrgica MG", sediada em Contagem, utiliza um SGBD SQL Server para gerenciar o controle de qualidade de suas chapas de aço. Recentemente, a empresa detectou que parâmetros técnicos de resistência foram alterados na base de dados, o que levou ao envio de um lote defeituoso para um cliente automotivo. A investigação inicial revelou os seguintes pontos:

1. Os desenvolvedores acessam o banco de dados de produção para realizar correções rápidas usando o usuário sa.
2. Não há registros de auditoria ativos porque a equipe técnica acreditava que isso reduziria a performance do servidor.
3. A senha do usuário administrativo era a mesma para todos os servidores da empresa.
4. O banco de dados não utiliza criptografia de dados em repouso.

Desafio Prático

Como aluno do curso Técnico em Desenvolvimento de Sistemas, você deve atuar como consultor de segurança e elaborar um relatório técnico contendo:

1. **Identificação de Falhas:** Aponte as três principais falhas de segurança do cenário acima, citando qual princípio da segurança da informação (confidencialidade, integridade ou disponibilidade) foi comprometido em cada uma.
2. **Proposta de Melhoria Técnica:**
 - Sugira um método para substituir o uso da conta sa por um modelo de controle de acesso mais seguro.
 - Descreva como implementar a rastreabilidade (auditoria) para garantir o não-repúdio das futuras alterações de parâmetros.
3. **Aplicação da Qualidade:** Utilize o Diagrama de Ishikawa para listar possíveis causas na categoria "Método" que levaram a este incidente.

4. **Conexão com a LGPD:** Explique se esse vazamento ou alteração de parâmetros técnicos poderia gerar sanções da ANPD (Autoridade Nacional de Proteção de Dados), justificando sua resposta com base no tipo de dado envolvido (pessoal vs. industrial).

Orientações para a Correção Sugerida

- **Falhas:** O uso de conta genérica (sa) compromete a integridade e o não-repúdio; a falta de auditoria impede a investigação de incidentes; a ausência de criptografia compromete a confidencialidade.
- **Melhoria:** Deve-se implementar o RBAC, criando usuários individuais e revogando o acesso administrativo direto das aplicações. A auditoria deve ser ativada via Server Audit focando na tabela de parâmetros técnicos.
- **LGPD:** Embora a alteração de parâmetros técnicos seja um segredo industrial e afete a qualidade do produto, a LGPD foca em dados pessoais. No entanto, se o banco contivesse dados de funcionários ou clientes vinculados a esses lotes, a lei seria aplicável e multas poderiam ser aplicadas.

Este material de apoio serve como base técnica para o desenvolvimento das capacidades previstas no plano de curso do SENAI MG, unindo a teoria rigorosa à necessidade prática do mercado industrial mineiro. A segurança de dados é, acima de tudo, uma postura ética e profissional do técnico, garantindo que a tecnologia sirva à sociedade com confiança e integridade.